

DATA PRIVACY IMPACT ASSESSMENT

DPIA Report: Applicant Assistant Chatbot System

Prepared under the Nigeria Data Protection Act (NDPA) 2023 and the General Application and Implementation Directive (GAID) 2025

Document ID	DPIA-2026-001	Version	2.0
Classification	Internal Use Only	Effective Date	August 26, 2026
Prepared By	Tosin Tuwase, Compliance Analyst (Practice)	Review Cycle	Annual
Regulatory Basis	NDPA 2023, S.28; GAID 2025, Art. 28 & Schedule 4	Status	Draft, Portfolio Document

Honesty note: This DPIA is a practice document built on the author's final-year Computer Science degree project (an Applicant Assistant Chatbot). It is structured against Schedule 4 of the NDPC's GAID (2025) to demonstrate applied knowledge of Nigerian data protection law. It does not represent a live enterprise deployment.

1. Executive Summary

1.1 Background, Objective and DPIA Trigger

This Data Privacy Impact Assessment (DPIA) evaluates the data handling practices of an Applicant Assistant Chatbot System: a public-facing application built to assist job applicants through automated natural language workflows. The system processes personally identifiable information (PII) submitted voluntarily by users during interactive chat sessions.

Under Article 28 of the Nigeria Data Protection Commission's General Application and Implementation Directive (GAID, 2025), a DPIA is mandatory where processing is likely to result in a high risk to the rights and freedoms of natural persons. Specifically, Article 28 names software systems built to communicate directly with data subjects, which this chatbot precisely represents, as a category of processing that triggers the mandatory DPIA obligation. This assessment is therefore not discretionary but a statutory requirement under the NDPA 2023 and its implementing directive.

1.2 Scope of Assessment

This assessment evaluates all points of data collection, ingestion, transit, storage, and disposal within the chatbot architecture, including the public user interface, backend processing nodes, and the cloud-hosted PostgreSQL database cluster.

2. System and Data Flow Description

2.1 Data Elements Collected

The chatbot system explicitly collects and processes the following consumer data elements:

- Direct Identifiers: Full Name, Email Address, and Phone Number.
- Metadata and Technical Data: IP Addresses, device types, and timestamped conversation logs.

2.2 Data Lifecycle and Storage Architecture

- Collection: Users voluntarily provide PII into the chat interface during interactive sessions.
- Transmission: Data is sent via API calls to the core processing engine.
- Storage: Structured applicant details and persistent chat logs are saved within a PostgreSQL relational database.
- Access: Access to stored database records is restricted exclusively to authorized human resource administrators and system developers using administrative consoles.

3. Data Protection Principles Mapping: NDPA Section 24 Compliance

Section 24 of the Nigeria Data Protection Act (NDPA) 2023 establishes eight core data protection principles. All eight are mapped below against the chatbot system's current implementation status.

NDPA Principle (S.24)	System Implementation Status	Status
Lawfulness, Fairness & Transparency	A mandatory click-to-accept Privacy Notice is displayed before a user can initiate a chat session, detailing exactly how their data will be used.	Compliant
Purpose Limitation	Data collected by the chatbot is used exclusively for processing applicant inquiries and tracking application status. It is logically segregated from marketing databases.	Compliant
Data Minimisation	The chatbot strictly requests only three data points (Name, Email, Phone Number). No unnecessary sensitive personal data is collected.	Compliant
Storage Limitation	A 180-day automated purge policy has been defined in policy but the implementing SQL cron-job script has not yet been deployed to the production environment. The control exists on paper only.	Gap Identified
Accuracy	No active mechanism currently exists for applicants to review or correct their stored personal data. An applicant data correction workflow has not been implemented.	Gap Identified
Integrity	TLS 1.3 for data-in-transit has been specified to protect data against unauthorized alteration while in transmission, but is pending full technical implementation and verification.	Gap Identified
Confidentiality	Data-at-rest encryption (AES-256), Role-Based Access Control (RBAC), and MFA for database administrators have been specified to prevent unauthorized access or disclosure, but remain pending full deployment. Insider access risk to candidate PII remains a residual high-impact concern until these controls are verified operational.	Gap Identified
Accountability	A compliance officer role has been assigned and this DPIA demonstrates documented accountability. Internal audit trails for data access are not yet operationally active.	Partial

4. Identified Privacy Risks

Risk 4.1: Unauthorized Internal Access to Candidate PII

Risk Description: Database administrators or backend developers with direct access to the PostgreSQL database layer could query, modify, or leak applicant personal data without authorization.

Impact Level: High

NDPA Violation: Breach of Duty of Care and the Confidentiality principle (S.24).

Risk 4.2: Interception of Data-In-Transit

Risk Description: If user inputs (names, emails, phone numbers) are transmitted over unencrypted HTTP channels from the frontend chat interface to the backend server, threat actors could intercept data via Man-in-the-Middle (MitM) attacks.

Impact Level: Medium

NDPA Violation: Failure to ensure secure processing channels: Confidentiality and Integrity principles (S.24).

Risk 4.3: Unrestricted or Indefinite Data Retention

Risk Description: The 180-day purge policy is defined in documentation but the automated implementation (SQL cron-job) has not been deployed to the production environment. Retaining applicant data indefinitely increases the blast radius in the event of a data breach.

Impact Level: High

NDPA Violation: Direct violation of the Storage Limitation Principle (S.24). This risk exists precisely because the control is not yet operationally active: it is not marked Compliant in Section 3.

Risk 4.4: Absence of Data Subject Correction Mechanism

Risk Description: Applicants currently have no mechanism to review, correct, or request deletion of their stored personal data. This creates an ongoing data accuracy risk and a potential breach of data subject rights.

Impact Level: Medium

NDPA Violation: Accuracy Principle (S.24) and data subject rights provisions under the NDPA.

5. Compliance Recommendations and Technical Mitigations

To mitigate the identified risks and achieve full regulatory readiness under the Nigeria Data Protection Commission (NDPC), the following technical controls must be implemented as priority actions:

5.1 Database-Level Encryption and Access Control (Addresses Risk 4.1)

- Action: Enforce transparent data encryption (TDE) at rest within the PostgreSQL database using AES-256.
- Control: Implement strict Role-Based Access Control (RBAC). Ensure that developers can only view masked data (e.g., j***n@email.com), while full unmasked data access requires executive multi-factor-authentication approval.

5.2 Mandatory Network Encryption (Addresses Risk 4.2)

- Action: Disable all non-secure HTTP endpoints across the chatbot web deployment.
- Control: Force Transport Layer Security (TLS 1.3) across all user-facing subdomains to encrypt payload packets containing PII during transit.

5.3 Automated Data Retention Policy Implementation (Addresses Risk 4.3)

- Action: Deploy the automated SQL cron-job script to the production PostgreSQL environment. The policy exists; the technical implementation does not.
- Control: The script must run automatically at midnight to identify, export to cold storage, and permanently delete application logs older than 180 days, adhering to the Storage Limitation principle.

5.4 Data Subject Rights Mechanism (Addresses Risk 4.4)

- Action: Implement a user-facing portal or email-based process allowing applicants to request access to, correction of, or deletion of their stored personal data.
- Control: Requests must be acknowledged within 72 hours and resolved within 30 days, consistent with NDPA data subject rights provisions.